

Relatório do trabalho de grupo

Controlo de acessos para mini-servidor Linux

Identificação do grupo

- **Grupo:** Breakout 04
- **Elementos:** Érica Lopes, Amadeu Dongo, Élio Barros
- Papéis assumidos:

Síntese do cenário

O cenário apresenta um mini-servidor Linux utilizado para alojar uma aplicação web, acessível por diferentes perfis de utilizadores: administradores, operadores web, auditores e visitantes técnicos. Foram identificados riscos relacionados com contas partilhadas, permissões excessivas, utilização frequente da conta root e acesso remoto sem controlo adequado. Para mitigar estes riscos, foi proposta uma solução baseada na gestão de utilizadores, grupos, permissões e regras de acesso seguro, seguindo o princípio do menor privilégio.

Perfis, grupos e responsabilidades

Perfil	Grupo Sugerido	Responsabilidade	Permissões necessárias	Permissões a evitar
Administrador	admins	Gerir utilizadores, serviços, atualizações e segurança	Leitura e escrita em todo o sistema, sudo	Utilização diária da conta root
Operador Web	web	Publicar e atualizar aplicações web	Escrita em public, leitura limitada em config	Alterar utilizadores e serviço crítico
Auditor	auditores	Consultar logs e documentação.	Leitura em logs/ e docs	Alteração de ficheiros
Visitante técnico	visitantes	Consultar informações e documentações públicas	Leitura em docs	Acesso a configurações e logs

Estrutura de Diretórios

```
erica@server-erica:~$ tree /opt/projeto-web
/opt/projeto-web
├── config
├── docs
├── logs
└── public
```

/opt/projeto-web/

Para proteger a aplicação, a propriedade base de /opt/projeto-web/ deve pertencer ao utilizador administrador ou root, e o grupo associado deve ser alterado caso a caso. O acesso de terceiros (outros utilizadores que não pertencem ao grupo da pasta) deve ser completamente bloqueado (--- ou 0).

public/

Contém os ficheiros da aplicação web (HTML, CSS, JavaScript, imagens).

Acesso:

- admins → leitura/escrita
- webops → leitura/escrita
- auditores → apenas leitura
- visitantes → sem acesso direto ao servidor, apenas acesso ao conteúdo disponibilizado publicamente pela aplicação web ou documentação autorizada.

config/

Contém configurações da aplicação, credenciais e parâmetros de execução.

Acesso:

- admins → leitura/escrita
- webops → leitura apenas (se necessário)
- auditores → sem acesso
- visitantes → sem acesso

Risco: exposição de passwords, tokens ou configurações sensíveis.

logs/

Contém registos de atividade e eventos.

Acesso:

- admins → leitura/escrita
- auditores → leitura
- webops → leitura limitada
- visitantes → sem acesso

docs/

Contém documentação técnica.

Acesso:

- admins → leitura/escrita
- auditores → leitura
- visitantes → leitura de documentação autorizada

Proposta de permissões

Caminho	Dono/Grupo sugerido	Permissão	Justificação
/opt/projeto-web/public	root:webops	775	Operadores que podem atualizar aplicações
/opt/projeto-web/config	root:admins	750	Apenas admins alteram configurações
/opt/projeto-web/logs	root:auditores	750	Auditores podem consultar logs

/opt/projeto-web/docs	root:auditores	755	Documentação acessível para consulta
-----------------------	----------------	-----	---

Criar grupo:

```
erica@server-erica:~$ sudo groupadd admins
[sudo: authenticate] Password:
erica@server-erica:~$ sudo groupadd admins
groupadd: o grupo 'admins' já existe
erica@server-erica:~$ sudo groupadd webops
erica@server-erica:~$ sudo groupadd auditores
erica@server-erica:~$ sudo groupadd visitantes
```

Criar utilizador:

```
erica@server-erica:~$ sudo useradd -m Amadeu
erica@server-erica:~$ sudo usermod -aG admins Amadeu
```

Definir dono e grupo

```
erica@server-erica:~$ sudo chown root:webops /opt/projeto-web/public
erica@server-erica:~$ sudo chown root:admins /opt/projeto-web/config
erica@server-erica:~$ sudo chown root:auditores /opt/projeto-web/logs
erica@server-erica:~$ sudo chown root:auditores /opt/projeto-web/docs
```

Aplicar permissões:

```
erica@server-erica:~$ sudo chmod 775 /opt/projeto-web/public/
erica@server-erica:~$ sudo chmod 750 /opt/projeto-web/config/
erica@server-erica:~$ sudo chmod 750 /opt/projeto-web/logs
erica@server-erica:~$ sudo chmod 755 /opt/projeto-web/docs
```

Regras de acesso remoto por SSH

Perfil	Pode aceder por SSH?	Tipo de autenticação	Justificação
Administrador	Sim	Chave SSH	Administração remota
Operador web	Sim	Chave SSH	Atualização de aplicação
Auditor	Sim	Chave SSH	Consulta de logs
Visitante técnico	Não	N/A	Não necessita acesso ao servidor

Riscos e medidas de mitigação

Risco	Impacto	Medidas de mitigação
Conta partilhada	Não é possível identificar responsáveis	Utilizar contas individuais
Uso frequente da root	Alterações críticas acidentais	Utilizar sudo apenas quando necessário
Permissões excessivas (777)	Exposição de dados e alterações indevidas	Aplicar menor privilégio
Passwords fracas	Acesso não autorizado	Passwords fortes e MFA quando possível
Configurações acessíveis a todos	Exposição de credenciais	Restringir acesso à pasta config
SSH sem regras	Intrusão remota	Utilizar chaves SSH e limitar acessos
Logs alteráveis por qualquer utilizador	Perda de evidências	Apenas admins escrevem logs

Conclusão

A proposta apresentada permitiu organizar os acessos ao mini-servidor Linux através da definição de perfis de utilizadores, grupos e permissões adequadas. Foram também estabelecidas regras para o acesso remoto por SSH e identificados os principais riscos de segurança, juntamente com medidas de mitigação. A solução segue o princípio do menor privilégio, garantindo que cada utilizador possui apenas os acessos necessários para desempenhar as suas funções, contribuindo para um ambiente mais seguro, organizado e fácil de administrar.